

UAT: Sign-in & User Roles (F1)

Test on the trial system (the administrator will provide the link and test accounts). · Follow each step on the live screen and compare with the Expected result. · Tick Pass / Fail and add evidence (document number / screenshot) for every step. · When done, sign off at the end of the document. · This set: 28 test cases.

Before you start (Preconditions)

- ☐ You have at least 1 active **admin** account (and you know its password) — created by the system administrator
- ☐ You have 1 active **manager** account (for testing read-only permissions)
- ☐ You have 1 active **member** account plus a test email inbox you can actually open (to receive invitation / reset links)
- ☐ Outgoing email (Resend) is working in the test environment
- ☐ You know the web addresses of both portals: the staff sign-in page (paste its web address) and the member sign-in page (paste its web address)

How to fill in: For each TC, mark **Pass / Fail** in the "Result" field and add evidence (document number / screenshot) in the "Notes" field.

TC-AUTH-01 — Admin signs in successfully (1 / 28)

Role: admin

#	Step	Expected result
1	Open the staff sign-in page (paste its web address)	The form appears with the Email field auto-focused, a Password field, a "Sign in" button, and a "Forgot your password?" link
2	Enter the correct admin email + password → press Sign in (or Enter)	The button briefly shows "Signing in..." , then the staff portal home page opens
3	Look at the menu in the top-right corner	You see the name/email + role badge = Admin + a Sign out option in the menu

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-02 — Wrong password: neutral message, no session created (2 / 28)

Role: admin

#	Step	Expected result
1	On the staff sign-in page, enter the correct admin email but the wrong password → Sign in	Shows "Email or password is incorrect." (does not say which field is wrong); no sign-in happens
2	Enter an email that is not in the system + a made-up password → Sign in	Shows the exact same message as step 1 (does not reveal whether the email really exists)
3	Watch the focus	Focus jumps back to the Email field

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-03 — Sign out + no leftover data in back/forward (3 / 28)

Role: admin

#	Step	Expected result
1	While signed in, open the user menu → click "Sign out"	The session ends and you are sent to the staff sign-in page
2	Press the browser back button	No protected data is shown — you are forced to sign in again
3	Try opening a staff web address that requires sign-in	You are sent to the Sign in page

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-04 — Open a sign-in-required address while not signed in → redirect + return (4 / 28)

Role: (not signed in) → admin

#	Step	Expected result
1	Sign out, then open directly a staff-only page such as the users page or the members page (paste its web address)	You are sent to the staff sign-in page (with a returnUrl value in the web address)
2	Sign in as admin successfully	You return to the page you originally requested (the users page), not the generic home page

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-05 — Idle timeout: warning box before time runs out (5 / 28)

Role: admin

#	Step	Expected result
1	Sign in, then leave it untouched for ~29 minutes	Before 30 minutes elapse, a "Still there?" box appears with a 1-minute countdown + "Stay signed in" / "Sign out now" buttons
2	Click "Stay signed in"	The box closes, the session is extended, and you can keep working without reloading
3	(New round) Leave it until the countdown finishes	You are signed out automatically + a toast appears saying you were signed out due to inactivity, and you are sent to Sign in

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-06 — Manager: signs in, sees a read-only view (6 / 28)

Role: manager

#	Step	Expected result
1	On the staff sign-in page, sign in with the manager account	You reach the staff portal landing page · role badge = Manager
2	Open a report/dashboard/list page (e.g. Members, Invoices)	Data loads normally and can be downloaded

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-07 — Manager: edit buttons hidden + writes rejected (history log entry recorded) (7 / 28)

Role: manager

#	Step	Expected result
1	The manager opens Users (the users page — paste its web address)	The user list is shown — the Disable / Enable buttons are hidden (not present in any row); the "Invite user" button is shown but disabled (cannot be clicked)
2	Look for create/edit/delete buttons on other pages	All change buttons are hidden for the manager
3	(If you can test at the system level) send a direct change request, such as disabling a user, as a manager	It is rejected with an insufficient-permissions message + an entry in the history log is recorded (manager-denied write attempt)

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-08 — Forgot password: request link + neutral message (8 / 28)

Role: member (or any role)

#	Step	Expected result
1	On the Sign in page, click "Forgot your password?" → go to the forgot-password page	The form appears with the Email field auto-focused and a "Send reset link" button
2	Enter an email that has a real account → Send reset link	Shows "If that email matches an account, a reset link is on the way."
3	Enter an email that is not in the system → Send reset link	Shows the exact same message (does not say whether an account exists)
4	Check the inbox of the real account	The reset email arrives within ~60 seconds

☐ PASS	☐ FAIL	Notes (time the email arrived): _____
-------------------------------	-------------------------------	---------------------------------------

TC-AUTH-09 — Reset succeeds: old password no longer works + sessions ended (9 / 28)

Role: member

#	Step	Expected result
1	Click the link in the email → the "Choose a new password" page	The New password field is auto-focused, with a Confirm new password field
2	Enter a new password that meets policy (≥12 characters) + confirm → "Update password"	Shows "Password updated. You can now sign in."
3	Sign in with the new password	Succeeds
4	Try signing in with the old password	Fails (the old password no longer works) and any existing session is ended

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-10 — Reset link expired / reused is rejected (10 / 28)

Role: member

#	Step	Expected result
1	Take the reset link that was already used (from TC-AUTH-09) and open it again	Shows "This reset link has expired. Request a new one." + a "Request a new link" link
2	(If you can test expiry) open a link older than 1 hour	Shows the same message + the option to request a new link

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-11 — New password fails policy, the failing rule is shown (11 / 28)

Role: member

#	Step	Expected result
1	On the Reset password page, enter a password shorter than 12 characters → Update password	Shows "Password must be at least 12 characters" ; nothing is saved
2	Enter a password that has appeared in a known data breach (e.g. Password123456)	Shows "This password appears in a known data breach. Choose a different one."
3	Enter New ≠ Confirm	Shows "Passwords must match"

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-12 — Resend button after waiting 60 seconds (12 / 28)

Role: member

#	Step	Expected result
1	On the forgot-password page, send a request and then stay on the post-send page	At first you cannot resend yet; there is a countdown "Resend (NNs)"
2	Wait ~60 seconds	The "Didn't get the email? Resend" button becomes clickable + there is advice to check the spam folder
3	Click Resend	A new email is sent (a second email arrives)

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-13 — Admin invites a new user → the invitee activates (13 / 28)

Role: admin → invitee

#	Step	Expected result
1	admin → Users → "Invite user"	The "Invite a new user" box opens with the Email address field auto-focused
2	Enter a test email + choose a Role (e.g. "Manager — read-only on finance") → "Send invitation"	A toast appears: "Invitation sent to ..." ; the new account shows status Pending in the table
3	Open the email → click the invitation link	Goes to the "Finish setting up your account" page; the Email field is locked (read-only); the Your name field is focused
4	Enter Your name + Choose a password (≥12) + confirm → "Activate account"	The account changes to Active and you are signed in automatically to the correct portal
5	(For Role = Member) in the invite box, try selecting the "Link to member company" field	The member search field is available only when Role = Member

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-14 — Invitation link expired / reused (14 / 28)

Role: invitee

#	Step	Expected result
1	Take the invitation link that was already used (from TC-AUTH-13) and open it again	Shows "This invitation has expired. Ask an administrator to send a new one." (no self-request button)
2	(If you can test expiry) open a link older than 7	Shows the same message

#	Step	Expected result
	days	

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-15 — Inviting an email already in the system is rejected (15 / 28)

Role: admin

#	Step	Expected result
1	admin → Invite user → enter the email of an account that already exists → Send invitation	It is rejected with an alert such as "That email is already on the system." ; no duplicate account is created

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-16 — Admin disables an account → that user cannot sign in + their sessions are ended (16 / 28)

Role: admin → disabled user

#	Step	Expected result
1	admin → Users → an active account row → click "Disable"	A confirmation box "Disable this account?" says access is removed immediately + all sessions are signed out (default focus is on Cancel)
2	Confirm	A toast appears: "... disabled."; the status becomes Disabled
3	Have the disabled user try to sign in	Shows "Your account has been disabled. Contact an administrator."
4	If the disabled user has a lingering session, try to keep working	The session is rejected; they must sign in again (and cannot, because the account is disabled)

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-17 — Destructive action requires confirmation (Cancel = nothing happens) (17 / 28)

Role: admin

#	Step	Expected result
1	admin → Users → click "Disable" , then in the confirmation box click Cancel (or Esc)	The box closes; no status change happens; the account is still active
2	Click "Enable" on a Disabled account, then Cancel	No change happens

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-18 — Re-enable an account (18 / 28)

Role: admin → re-enabled user

#	Step	Expected result
1	admin → Users → a Disabled account → click "Enable" → confirm "Re-enable this account?"	A toast appears: "... re-enabled."; the status returns to Active
2	Have the re-enabled user try to sign in	They can sign in normally

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-19 — Last-admin protection (prevent ending up with 0 admins) (19 / 28)

Role: admin

#	Step	Expected result
1	With only 1 active admin in the system, open Users and look at your own row	Your own row has no Disable button (it shows "That's you")
2	(If you can test at the system level) try to disable/downgrade the last admin	It is rejected with a message saying there must always be at least 1 admin

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-20 — Member enters the portal + cross-portal protection (20 / 28)

Role: member

#	Step	Expected result
1	On the member sign-in page, sign in with the member account	You reach the member portal landing page · role badge = Member
2	While signed in as a member, try opening a staff web address such as the admin home or users page	You are rejected/redirected; you do not see staff data

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-21 — Wrong portal → neutral message (anti-enumeration) (21 / 28)

Role: member ↔ staff

#	Step	Expected result
1	Take a member account and sign in at the staff sign-in page (paste its web address) with the correct password	It is rejected with " Email or password is incorrect. " (deliberately the same message as a wrong password — it does not say it was because of the wrong portal)
2	Take a staff account and sign in at the member sign-in page	It is rejected with the same message

Designer's note: the original spec mentioned "a message helping you find the right URL", but the system chose a single neutral message to prevent account guessing — so the expected result is the neutral message.

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-22 — Change your own password: other sessions are ended, this device stays (22 / 28)

Role: admin or member

#	Step	Expected result
1	Sign in to the same account in 2 browsers/windows (context A + B)	Both work
2	In context A, open Account settings (paste its web address) → enter Current + New + Confirm → " Change password "	A toast appears: " Password updated. Other sessions have been signed out. "
3	Keep working in context A	You are still signed in; no need to sign in again
4	Go back to context B and work/reload	The session is ended; you must sign in again

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-23 — Change password: current password wrong / new password fails policy (23 / 28)

Role: admin or member

#	Step	Expected result
1	Account settings → enter the wrong Current password + a correct New → Change password	Shows " Current password is incorrect. "; nothing changes; focus returns to the Current field
2	Enter the correct Current, but New = the existing password	Shows " Pick a different password — the new one cannot equal the current one. "
3	Enter a New shorter than 12 characters	Shows " Password must be at least 12 characters "

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-24 — Repeated password changes with the wrong current password get rate-limited (24 / 28)

Role: admin or member

#	Step	Expected result
1	Click Change password with the wrong Current password repeatedly until the threshold	You are rate-limited; shows "Too many attempts. Please wait a few minutes and try again."

i If you are testing on a preview and see UpstashError: max requests limit, run the test again (the Upstash quota is exhausted — it is not a bug).

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-25 — Account locked after 5 wrong passwords in 15 minutes (25 / 28)

Role: admin (test account)

#	Step	Expected result
1	On the staff sign-in page, enter the correct email and the wrong password 5 times within 15 minutes	On the next attempts it shows "Too many failed attempts. Try again later." (the account is locked for 15 minutes)
2	Try entering the correct password while locked	You still cannot sign in (it is locked)
3	Wait out the lock window (15 minutes), or use Forgot password	It unlocks on its own and you can sign in

☐ PASS	☐ FAIL	Notes: _____
-------------------------------	-------------------------------	--------------

TC-AUTH-26 — i18n: every auth page is complete in all 3 languages (EN / TH / SV) (26 / 28)

Role: admin

#	Step	Expected result
1	Switch the app language to TH , then open Sign in / Forgot password / Reset / Invite / Change password	Every label/button/error message is shown fully in Thai, with no raw keys (e.g. auth.signIn.title)
2	Switch to SV and repeat	Shown fully in Swedish, with no untranslated fallback

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-27 — a11y + 320px: keyboard-only + narrow screen (27 / 28)

Role: admin

#	Step	Expected result
1	Open Sign in and use keyboard only (no mouse)	The Email field is focused on load · Tab moves through the fields · Enter submits the form · there is a "Skip to main content" as the first focus point · focus outlines are clearly visible
2	Trigger a form error, then watch the focus	Focus moves to the first failing field (does not stay on the button)
3	Shrink the screen to 320px and open every auth page	No horizontal scroll, no text cut off
4	(idle dialog) open the warning box, then press Esc	The box closes; focus returns to its previous spot

i On local dev you may see flaky a11y/perf results (320px reflow, target-size, sign-in timeout) — treat this as expected noise. The reliable run is on the preview deploy.

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

TC-AUTH-28 — History log: auth events fully recorded + cannot be changed

(28 / 28)

Role: admin

#	Step	Expected result
1	Perform a full set of auth events (sign-in success/failure, sign-out, reset request, reset success, change password, invite, disable, enable, lock, manager-denied, etc.)	Each event is appended to the history log with the time (UTC), actor (or anonymous), type, target, source IP, a short summary, and a request id
2	Try to edit/delete a history log entry through any screen	Not possible — append-only (kept for at least 5 years)
3	Confirm that idle/absolute timeouts are not recorded	Normal timeouts do not appear in the log (by design)

i The history log viewer for filtering is an F9 (insights) feature — in F1 you can verify at the database / automated-test level.

☐ PASS	☐ FAIL	Notes: _____
--------------------------------------	--------------------------------------	--------------

Summary & sign-off (F1 Auth & RBAC)

Item	Value
Total number of TCs	28
Passed	_____
Failed	_____ (list TC numbers: _____)
Run on (preview URL)	_____
Test date	_____

Role	Name	Signature	Date
UAT approver (SweCham)			
System administrator			
Security sign-off (security checklist)			

If you find a problem, note the symptom and the failing TC number, then report it to the system administrator.